CYBERSECURITY LAB REPORT • MITRE ATT&CK FRAMEWORK

Lab 1: From CTI to SOC Investigation & ATT&CK Mapping

Course: AI-Enhanced Cybersecurity • Incident Analysis & Threat Hunting

STUDENTS & SUBMISSION TEAM

Rony Levy & Noa Cohen

Cyber Lab Group Submission

1 | Selected CTI Report & Threat Intelligence Summary

REPORT CITATION & SOURCE DETAILS

• **Report Title:** Midnight Blizzard: Guidance for responders on nation-state attack

• **Publisher:** Microsoft Threat Intelligence | Date: January 25, 2024

• **Direct Source URL:** https://www.microsoft.com/en-us/security/blog/2024/01/25/midnight-blizzard-guidance-for-responders-on-nation-state-attack/

Attack Summary:

In late 2023, the Russian state-sponsored actor Midnight Blizzard (also tracked as NOBELIUM / APT29) targeted Microsoft's corporate Microsoft 365 / Entra ID environment. The objective was espionage: access to email of senior leadership and of cybersecurity and legal staff. The actor first ran a password spray attack, deliberately limited to a low number of attempts to avoid detection, and compromised a legacy, non-production test tenant account that did not have MFA enabled. The attempts were routed through residential proxy infrastructure to hide their origin. Using this access, the actor compromised a legacy test OAuth application that had elevated access to the corporate environment, created additional malicious OAuth applications, and created a new user account to grant consent to those applications. The legacy application was then used to grant the Office 365 Exchange Online full_access_as_app role, which allows access to mailboxes. Finally, the actor used these applications to access corporate mailboxes, mainly through Exchange Web Services (EWS).

2 | Attack Flow Sequence & Evidence Breakdown

The sequence diagram below models the attack progression, using only stages supported by the source:

[Stage 1: Credential Access / Initial Access]
| Low-volume password spray via residential proxies → legacy test account (no MFA) compromised
▼
[Stage 2: Compromise of the legacy OAuth application]
| Compromise of legacy test OAuth app with elevated access to the corporate tenant
▼
[Stage 3: Persistence]
| Creation of malicious OAuth apps + new user account to grant consent
▼
[Stage 4: Privilege Escalation]
| Grant of full_access_as_app (Exchange Online) role to the malicious apps
▼
[Stage 5: Collection]
| Access to leadership, security and legal mailboxes via EWS

• **Empirical Facts (Observed Evidence):** low-volume password spray; residential proxy use; compromised legacy non-production test account without MFA; compromised legacy test OAuth app; creation of malicious OAuth apps and a new user account; grant of full_access_as_app; mailbox access via EWS.

• **Analyst Inferences (Deductions):** bulk email exfiltration and deliberate selection of the test tenant because it lacked MFA are possibilities, not established facts; the report does not establish the volume or the reason this account was selected. The telemetry and alert logic in the SOC investigation column are our proposals, not observed report evidence. Attribution to Midnight Blizzard is Microsoft's assessment, not independently verified by us.

3 | MITRE ATT&CK Mapping

Mapping of observable behaviors to MITRE ATT&CK Enterprise tactics and multi-tier SOC triage procedures:

Observed Behavior	Tactic	Technique & ID	Evidence & Rationale	SOC Telemetry & Investigation
Low-volume password spray against accounts, incl. a legacy test account without MFA	Credential Access	Brute Force: Password Spraying [T1110.003] https://attack.mitre.org/techniques/T1110/003/	Evidence: Report states password spray with a limited number of attempts. Rationale: The reported password spray uses a small set of passwords across accounts, with few attempts per account, consistent with T1110.003. Source section: Initial access through password spray.	Telemetry: Entra ID sign-in logs. Tier 1: Correlate low-volume sign-in failures across targeted accounts over extended periods and rotating IPs/ASNs; do not rely only on a shared source IP. Tier 2: Preserve logs; correlate successful sign-ins with failures and subsequent actions; assess scope, then reset credentials and enforce MFA.
Sign-in with the compromised legacy test account	Initial Access	Valid Accounts: Cloud Accounts [T1078.004] https://attack.mitre.org/techniques/T1078/004/	Evidence: Actor logged in with the account obtained through the spray. Rationale: Use of a real, existing cloud account. Source section: Initial access through password spray.	Telemetry: Entra ID sign-in logs. Tier 1: Sign-in to a dormant/test account without MFA. Tier 2: Review every action taken by that account after sign-in.

Observed Behavior	Tactic	Technique & ID	Evidence & Rationale	SOC Telemetry & Investigation
Spray and access routed through residential proxies	Command and Control (provisional)	Proxy: External Proxy [T1090.002] (provisional) https://attack.mitre.org/techniques/T1090/002/	Evidence: Report states residential proxy infrastructure hid the attack source. Rationale: Residential proxies relay traffic and conceal its origin, supporting T1090.002 as an analyst mapping. The report documents cloud sign-in and service access through proxies, but does not independently establish a C2 channel; the Command and Control classification is provisional. Source section: Use of residential proxy infrastructure.	Telemetry: Sign-in logs (IP, ASN, User-Agent) + threat intel enrichment. Tier 1: Risky sign-ins from residential IPs to admin/test accounts. Tier 2: Correlate IPs across accounts and time; many IPs per identity.
New user account created to grant consent to malicious apps	Persistence	Create Account: Cloud Account [T1136.003] https://attack.mitre.org/techniques/T1136/003/	Evidence: Report states a new user account was created for consent. Rationale: Creation of a cloud user account matches T1136.003. The reported purpose was to grant app consent; continued access is a possible effect, not a separately established purpose. Source section: Malicious use of OAuth applications.	Telemetry: Entra ID audit logs ("Add user"). Tier 1: New account created by an unusual actor. Tier 2: Check change ticket; review consents made by the account.

Observed Behavior	Tactic	Technique & ID	Evidence & Rationale	SOC Telemetry & Investigation
Malicious OAuth apps granted the full_access_as_app role	Privilege Escalation / Persistence	Account Manipulation: Additional Cloud Roles [T1098.003] https://attack.mitre.org/techniques/T1098/003/	Evidence: Legacy app used to grant full_access_as_app to actor apps. Rationale: New, higher permissions added to cloud identities. Source section: Malicious use of OAuth applications.	Telemetry: Audit logs ("Add app role assignment to service principal", "Consent to application"). Tier 1: High-severity alert on mailbox-wide roles. Tier 2: Preserve audit records; identify the granting identity and affected apps; assess scope, then revoke malicious permissions.
Corporate mailboxes accessed using the malicious apps	Collection	Email Collection: Remote Email Collection [T1114.002] https://attack.mitre.org/techniques/T1114/002/	Evidence: Report states leadership, security and legal mailboxes were accessed, mainly via EWS. Rationale: Remote, programmatic mailbox access. Source section: Collection via Exchange Web Services.	Telemetry: M365 Unified Audit Log (MailItemsAccessed; ClientInfoString for EWS), correlated with service principal sign-in logs, where available. Tier 1: Triage unusual mailbox access by new or unfamiliar apps, including low-volume activity; compare with approved app use. Tier 2: Preserve logs; identify accessed messages where records allow, assess exposure and logging gaps; escalate to IR/legal. Access does not prove human reading.

4 | SOC Investigation Notes

The SOC Telemetry & Investigation column in Section 3 provides proposed telemetry and Tier 1 and Tier 2 tasks for all six behaviors. Triage should validate legitimate use before escalation; an ATT&CK mapping alone does not establish malicious intent. Preserve relevant records before containment changes and account for log availability and retention.

5 | Review of the Proxy Mapping

Uncertain mapping: We mapped the use of residential proxies to External Proxy (T1090.002). The report confirms that Midnight Blizzard routed password-spray attempts and later access to the tenant and Exchange Online through these proxies. However, it does not describe a separate command-and-control channel, so the connection to the Command and Control tactic is less certain than the other mappings.

Alternative interpretation: The proxies may have been used to hide the source of sign-in attempts and mailbox access, rather than to relay commands from a compromised system. This would still support the observed proxy behavior, but would provide a weaker basis for assigning the Command and Control tactic.

Additional evidence: Network or endpoint records linking a compromised system to attacker-controlled infrastructure through a proxy, especially records of commands and responses, would strengthen the mapping. By contrast, complete logs showing only authentication and Exchange Online requests would favor the alternative interpretation. Incomplete logs would not be enough to rule out command-and-control activity.

Conclusion: We retained T1090.002 as a provisional mapping because the use of external proxies is documented, while their role in command and control is not established by the report. The other mappings do not depend on this interpretation.